Operating Models Worksheet: Control Ownership Matrix

Operating Models · 11:30 – 12:00

Work in groups of 3–4 with your Day 2 architecture sketch. For each control, mark who runs it today and whether it is a must-have before go-live. "We don't know" is a finding, not a failure. The last row is for a control of your own. If you run short of time, start with the Day 3 configuration record and the Day 4 guardrail rows: they are new this week.

Control	Who runs it today CSOB Security / CSOB IT or platform / parent organisation / vendor / nobody / unknown	Must-have or nice-to-have (if nice-to-have: needed by when?)	Evidence CSOB would ask for
Retrieval access trimming (Day 1)			
Tool and MCP server approval and scopes (Day 2)			
Boundary policy: who may do what, decided outside the agent (Day 2)			
Gateway filtering of prompts and responses (Day 3)			
System prompt change control (Day 3)			
Agent configuration record (AI-BoM) and re-testing after changes (Day 3)			
Escalation review (Day 3)			
Tracing and alerting (Day 4)			
Guardrail tuning and monitoring (Day 4)			
Cost monitoring (Day 4)			
Residency and subprocessor checks (Day 4)			
Your own control:			

Circle two controls where the owner is unclear or sits outside CSOB

Control 1: the question you would ask its owner	
Control 2: the question you would ask its owner	